



Information Security Policy

HostFi, Inc. — hostfi.ai

Document Owner	Kevin Aramalla, Founder & CEO
Effective Date	February 1, 2026
Last Reviewed	February 17, 2026
Next Review	August 2026
Classification	Internal / Shared with Partners

1. Purpose

This policy establishes the information security framework for HostFi to protect the confidentiality, integrity, and availability of customer data, financial information, and company systems. It applies to all systems, data, and personnel involved in the operation of HostFi's products and services.

2. Scope

This policy covers:

- All production systems and infrastructure (web application, APIs, databases)
- Customer data including financial records, property information, and integration credentials
- Third-party services and integrations (Plaid, Stripe, Supabase, Vercel, PMS integrations)
- All personnel with access to production systems or customer data

3. Information Security Principles

- **Least Privilege:** Access to systems and data is granted on a need-to-know basis with minimum necessary permissions.
- **Defense in Depth:** Multiple layers of security controls protect against threats at the network, application, and data layers.
- **Encryption by Default:** All data is encrypted in transit and at rest.
- **Data Minimization:** Only data necessary for service delivery is collected and retained.

4. Infrastructure Security

4.1 Hosting & Compute

HostFi is deployed on Vercel (SOC 2 Type II certified), providing enterprise-grade DDoS protection, Web Application Firewall (WAF), automatic SSL/TLS management, and global edge network distribution.

4.2 Database

Application data is stored in Supabase (SOC 2 Type II certified), built on PostgreSQL with data centers in the United States. Row Level Security (RLS) policies enforce per-user data isolation at the database level.

4.3 Payment Processing

All payment processing is handled by Stripe (PCI DSS Level 1 certified). HostFi never stores, processes, or transmits credit card numbers or payment credentials.

5. Encryption

- **In Transit:** All communications encrypted via TLS 1.2+. HSTS is enforced on all domains.

- **At Rest:** Database encryption via AES-256, managed by Supabase/AWS infrastructure.
- **Credentials:** Third-party integration tokens and API keys are stored encrypted in the database and never exposed to client-side code.
- **Secrets Management:** Environment variables and API keys are managed through Vercel's encrypted environment variable system, with separate values for production, preview, and development.

6. Authentication & Access Control

- User authentication via Supabase Auth with bcrypt password hashing and secure session tokens
- Support for Google OAuth 2.0 single sign-on
- Multi-factor authentication (TOTP) available via Supabase Auth
- All API endpoints enforce server-side authentication — unauthenticated requests are rejected before data access
- Row Level Security (RLS) enforced at the PostgreSQL level prevents cross-user data access
- OAuth 2.0 used for all third-party integrations — HostFi never stores third-party passwords

7. Financial Data Handling

- Bank connectivity powered by Plaid (SOC 2 Type II certified) — HostFi never accesses bank login credentials
- Only transaction data necessary for expense matching and tax categorization is stored
- No full bank account numbers or routing numbers are stored
- Customer financial data is never sold, shared, or disclosed to third parties for marketing purposes
- Users can disconnect integrations and delete their data at any time

8. Monitoring & Logging

- Application errors and security events are logged via Vercel's observability platform
- Database query performance and errors monitored via Supabase dashboard
- Authentication events (logins, failed attempts) are logged
- Integration webhook events are logged for audit purposes

9. Incident Response

In the event of a suspected or confirmed security incident:

1. **Identification:** Detect and classify the incident severity
2. **Containment:** Isolate affected systems to prevent further exposure
3. **Notification:** Notify affected users within 72 hours with incident details and recommended actions
4. **Remediation:** Fix the root cause and restore affected systems
5. **Post-Mortem:** Document lessons learned and update security controls as needed

10. Vulnerability Management

- Dependencies are monitored for known vulnerabilities via automated tooling
- Security patches are applied promptly upon identification
- Responsible disclosure reports can be sent to **security@hostfi.ai**

11. Data Retention & Disposal

- Customer data is retained for the duration of the account plus 30 days after deletion request

- Users can export their data and request account deletion from dashboard settings
- Backups are encrypted and retained per Supabase's backup policy (daily, 7-day retention)

12. Third-Party Risk Management

All third-party vendors handling customer data are evaluated for security compliance. Current vendors and their certifications:

- **Supabase** — SOC 2 Type II (database, auth)
- **Vercel** — SOC 2 Type II (hosting, edge, CDN)
- **Stripe** — PCI DSS Level 1 (payments)
- **Plaid** — SOC 2 Type II (financial data)
- **Postmark** — SOC 2 Type II (transactional email)

13. Policy Review

This policy is reviewed semi-annually or upon significant changes to systems, services, or regulatory requirements. Updates are approved by the document owner.